



Government
Digital Service



Department for
Science, Innovation
& Technology

Aligning AWS Key Management Service (KMS) with Secure by Design

October 2025

Contents

Background	3
Purpose	3
Secure by Design on the UK Government Security website	3
Implementing AWS KMS so it's aligned with Secure by Design	4
1. Key governance and ownership	4
2. Key material security	5
3. Key classification and risk management	6
4. Developer integration and usability	6
5. Logging, monitoring and incident response	7
6. Cross-account key architecture	7
7. Access control and least privilege	8
8. Layered security and encryption context	8
9. Compliance and continuous assurance	9
10. Key life cycle management and secure change	9
More information	10

Background

AWS Key Management Service (KMS) is a fully managed service that helps users create, manage and control encryption keys to secure data across AWS. It integrates with services like Amazon S3, RDS and EBS, and supports both symmetric and asymmetric encryption.

AWS KMS simplifies encryption management and strengthens cloud data security with features like:

- automatic key rotation
- Identity Access Management (IAM) controls
- detailed auditing through CloudTrail

The Secure by Design approach is a government framework which embeds cyber security into digital services from the outset. Its goal is to make security an integral, proactive part of all government digital systems, rather than an afterthought.

Purpose

The purpose of this guide is to help government organisations implement AWS KMS by aligning it with the government's Secure by Design approach. It covers both governance and technical implementation, making sure that cryptographic controls protect sensitive information and provide transparency and accountability throughout the key life cycle.

By integrating the [Secure by Design principles](#), this framework empowers organisations to establish a mature, adaptive and resilient encryption posture when using AWS.

Secure by Design on the UK Government Security website

- [Secure by Design policy](#)
- [Implementing Secure by Design](#)
- [Guide to adopting Secure by Design](#)

Implementing AWS KMS so it's aligned with Secure by Design

Each section of this guidance demonstrates how practical key management supports organisational security and risk management goals while embedding specific [Secure by Design principles](#).

By combining governance, operational practices, monitoring and life cycle management, AWS KMS helps organisations maintain a secure and auditable cloud environment.

1. Key governance and ownership

By establishing clear ownership of cryptographic keys you can make sure there's accountability throughout the key life cycle, and embed Secure by Design principle 1: Create responsibility for cyber security risk.

In AWS KMS, assigning a custodian for each customer managed key (CMK) means that creation, policy management, rotation and retirement are actively managed. Key owners are responsible for:

- approving access requests
- reviewing usage
- ensuring keys comply with organisational security policies

Without effective management, keys can be misused, orphaned or left unmonitored. This increases the risk of data exposure or non-compliance. Conducting periodic [risk assessments](#) helps identify and mitigate the risks.

Administrative privileges

You should separate administrative privileges from operational usage through [privileged access management](#). For example, a security team might manage key policies and rotation schedules, while application teams perform encryption and decryption operations. Tagging keys with metadata such as 'Owner', 'Environment' or 'Project' makes auditing, reporting and operational monitoring easier.

Infrastructure as Code (IaC) tools

Using Infrastructure as Code (IaC) tools like [AWS CloudFormation](#) or [Terraform](#), you can automate the creation of AWS KMS keys with predefined policies, tags and rotation schedules.

Automated pipelines make misconfigurations less likely and help make deployment consistent across multiple AWS accounts and environments.

Policy-as-code approaches mean policies can be validated automatically before deployment so they comply with internal standards.

Central key inventories

Maintaining a central key inventory lets you:

- track active keys
- identify unused or orphaned keys
- capture evidence for audits

Integration with [AWS Config](#) and [CloudWatch](#) allows you to carry out automated monitoring of key usage, policy changes and compliance status. You should integrate key governance with broader risk management processes to make sure that encryption practices support your organisation's risk appetite.

2. Key material security

By protecting cryptographic key material, you'll meet Secure by Design principle 2: Source secure technology products.

AWS KMS relies on FIPS-validated hardware security modules (HSMs) to generate, store and use keys securely. Because plaintext keys never leave the secure boundary, they're less likely to be accidentally exposed or compromised. Using certified cryptographic modules provides strong assurance that keys are protected against both software and hardware attacks.

Organisations that handle sensitive data benefit from this high-assurance environment to meet compliance requirements. [Performing threat modelling](#) may reveal potential threats which can be factored into risk management and mitigation plans.

Keys can be:

- symmetric, which makes them suitable for bulk data encryption
- asymmetric, which means you can use them for signing and verification operations

Applying metadata, such as [encryption context](#), lets you bind keys to specific workloads, datasets or applications.

AWS KMS supports automatic key rotation for CMKs on an annual schedule. Envelope encryption allows large datasets to be encrypted with a local data key, which is itself encrypted with a CMK. This approach minimises the number of direct CMK operations while keeping the data encrypted efficiently.

Using envelope encryption in combination with caching strategies can significantly improve performance while maintaining strong security guarantees.

Monitoring key usage through [CloudTrail](#), [CloudWatch](#), or [Security Hub](#) lets you detect unusual activity, such as spikes in decryption requests or access from unexpected accounts or regions. Alerting and automated responses can prevent potential misuse before it escalates into a security incident. When you import key material, you should check it meets your organisation's standards and make sure you've logged all actions so they can be audited.

3. Key classification and risk management

You should manage keys depending on how sensitive their data is. This aligns with [Secure by Design Principle 3](#): Adopt a risk-driven approach.

Data should be assigned keys that provide appropriate levels of protection and classified based on:

- criticality
- regulatory requirements
- confidentiality

This may help you assign appropriate controls to high-value or sensitive data, while lower-risk data is encrypted efficiently without unnecessary complexity.

You can help prevent misuse by using conditional access controls, such as restricting key usage to specific services, applications or network locations. You should carry out regular reviews of key access policies to make sure they're aligned with business changes. By adopting a risk-based approach, organisations can prioritise resources to protect their most critical assets.

AWS KMS lets you tag keys and specify [encryption context](#). This means you can enforce granular policies in a dynamic way. For example, a key can be configured to encrypt only specific [S3 buckets](#), [DynamoDB tables](#) or [Redshift clusters](#). This reduces the risk of unclassified or non-critical data being accidentally encrypted. You can use conditional grants if you need to allow temporary or limited access.

Monitoring key usage patterns can reveal unexpected patterns, like someone using them outside normal hours or from unusual accounts. By integrating anomaly detection tools and automated alerts, you can mitigate risks proactively and respond rapidly to potential threats before sensitive data is compromised. This aligns with the Secure by Design activity [Managing observability](#).

4. Developer integration and usability

Security controls must be practical and usable, reflecting Secure by Design principle 4: Design usable security controls.

AWS KMS simplifies developer integration using key aliases, software development kits (SDKs) and templates. This makes sure encryption is applied consistently and means developers do not have to manage complex cryptographic details. Usable controls help people follow organisational security policies, reducing the likelihood of human error.

The [AWS Encryption SDK](#) automates key handling, metadata management and cryptographic operations, so that encryption is applied correctly across multiple programming languages and platforms. Using pre-configured templates for key creation and IAM policies help enforce best practice within your organisation.

Developers can integrate AWS KMS using SDKs (Python, Java, .NET, JavaScript) and use envelope encryption with automatic data key caching. This approach provides high-performance encryption for large datasets while maintaining secure key handling.

By integrating AWS KMS with Continuous Integration and Continuous Delivery (CI/CD) pipelines, you can embed security in the life cycle and carry out automated testing of encryption functionality.

Self-service workflows for key creation, access requests and grants let developers work efficiently while complying with organisational policies. Meanwhile, logging and monitoring all interactions developers have with keys provides accountability and traceability.

5. Logging, monitoring and incident response

It's critical to track key activity, and by doing so, you'll meet Secure by Design principle 5: Build in detect and respond security. AWS KMS integrates with [CloudTrail](#), [CloudWatch](#) and [Security Hub](#), which helps organisations promptly detect, investigate and remediate unusual activity promptly. Logging all key operations makes sure there's visibility and supports forensic investigations and audits.

Anomalies, such as unexpected access patterns or spikes in usage, trigger alerts which can be routed to security information and event management (SIEM) systems or security teams. By regularly reviewing logs and using automated reporting, you can identify misconfigurations, inactive keys or policy deviations.

Integrating AWS KMS with [CloudWatch Events](#) and [Lambda](#) means you can automate incident responses. For example, suspicious activity could trigger revocation of temporary grants, alias redirection or immediate key rotation. Threshold-based alerts and automated remediation workflows reduce response time and limit potential damage.

By carrying out periodic security exercises, such as simulated attacks or access tests, you can confirm that monitoring, detection and response controls are working as intended. This will increase your organisation's confidence in its overall encryption posture and can be linked to the Cyber Assessment Framework (CAF) [objective C: Detecting cyber security events](#).

6. Cross-account key architecture

[AWS KMS cross-account setups](#) make sure keys are consistently available across accounts. This encourages collaboration, supports disaster recovery and operational resilience, and aligns with Secure by Design principle 6: Design flexible architectures.

Alias redirection keeps applications operating seamlessly when keys are rotated or replaced. Separating keys by service, environment or project makes them less likely to be misused by accident, while temporary grants allow secure third-party access for set periods.

AWS KMS multi-region keys automatically replicate CMKs to other regions. This provides low-latency decryption and supports disaster recovery strategies. Cross-account grants let

certain accounts or roles use CMKs securely and you can create policies to control how much access users have and for how long. By monitoring key usage across regions you can detect unauthorised activity and make sure organisational policies are being followed.

By testing your organisation's replication and failover processes, you can make sure systems remain available and resilient during outages or region failures.

7. Access control and least privilege

By limiting access, you can reduce attack surfaces and meet Secure by Design principle 7: Minimise the attack surface. AWS KMS enforces least privilege by only giving authorised users or services access to keys, with administrative functions separated from operational use.

Network-level restrictions, such as [VPC endpoints](#), prevent key traffic on public networks. Encryption context metadata can ensure keys are used only for authorised datasets, projects or applications.

You can combine AWS KMS key policies, IAM policies and grants to enforce fine-grained access control (FGAC). [IAM Access Analyzer](#) can be used with KMS to detect over-permissive or potentially risky keys. Using temporary grants and per-service permissions reduces long-term exposure while keeping operations efficient.

Carry out regular audits and automated alerts for unused or over-permissive keys so least privilege is consistently enforced. This reduces the risk of unauthorised access or accidental misuse.

8. Layered security and encryption context

Layered controls embody Secure by Design principle 8: Defend in depth. Because AWS KMS combines IAM roles, key policies, grants, network restrictions and encryption context, if there is a gap in one control, others can continue to protect key material. Each layer reinforces the overall security posture, providing resilience against internal or external threats.

Encryption context binds keys to specific conditions. This stops them from being decrypted outside approved scenarios. Temporary grants reduce exposure time, while organisation-wide policies make sure usage across accounts is consistent.

You can combine envelope encryption across AWS services ([S3](#), [EBS](#), [RDS](#), [Redshift](#)) with IAM and key policy controls to put a multi-layered defence strategy in place. Logging and monitoring each layer helps detect anomalies and provides evidence of effective layered protection.

By regularly testing layered security through controlled simulations or penetration tests, you can validate defences and guarantee operational readiness.

9. Compliance and continuous assurance

By continuously verifying security controls, you'll meet Secure by Design principle 9: Embed continuous assurance. AWS KMS integrates with [AWS Config](#), [Security Hub](#) and [CloudTrail](#) to provide ongoing compliance monitoring for key rotation, enabled status and access policies.

Regularly reviewing logs and using automated reporting makes it easier to follow your organisation's policy and be ready for audits. Integration with CI/CD pipelines makes sure that new applications automatically adhere to encryption standards.

AWS Config rules and Security Hub integration can automatically identify misconfigured policies or keys that are not compliant. Automated remediation, anomaly detection and dashboards provide continuous assurance that encryption practices meet organisational and regulatory requirements.

Being aware of emerging threats and using feedback from audits will help you continuously refine key policies. This keeps security controls relevant and effective.

10. Key life cycle management and secure change

Managing key changes securely can help you meet Secure by Design principle 10: Make changes securely. AWS KMS life cycle management includes rotation, alias switching and scheduled deletion. This means updates occur safely, without any loss of access and preventing accidental exposure.

Auditing life cycle events allows you to provide transparency and accountability, while putting automated workflows in place means you can reduce human error. Rotation makes sure that new operations use updated keys without losing access to previously encrypted data.

Version-controlled [CloudFormation](#) or [Terraform](#) templates can automate key creation, policy assignment and rotation schedules. You can prevent accidental key loss by using scheduled deletion with configurable waiting periods. Use alias switching to keep operations running during key updates.

By monitoring key life cycle events, you can make sure that all changes are compliant, auditable and secure. This reduces your organisation's operational and security risk.

More information

- [Secure by Design Principles \(UK Government Security\)](#)
- [Secure by Design Activities \(UK Government Security\)](#)
- [Data Protection Act 2018 \(Legislation.gov.uk\)](#)
- [Choosing and configuring a KMS for secure key management in the cloud \(NCSC\)](#)